Introduction to Ethical Hacking

1	Motivation
2	Terminology
3	Methodologies & Frameworks
4	Legal & Ethical Boundaries
5	Important Bodies & Organizations
6	Certifications

Introduction to Ethical Hacking

1	Motivation
2	Terminology
3	Methodologies & Frameworks
4	Legal & Ethical Boundaries
5	Important Bodies & Organizations
6	Certifications

Why is Ethical Hacking / Penetration-Testing needed?

Introduction to Ethical Hacking

1	Motivation
2	Terminology
3	Methodologies & Frameworks
4	Legal & Ethical Boundaries
5	Important Bodies & Organizations
6	Certifications

2 Terminology - Red, Blue and Purple Teams

- red team, blue team, and purple team describe different roles in testing and improving an organization's defenses

- **red team**
  - simulates real-world attackers to test how well systems, people, and defenses hold up against realistic threats
  - focuses on offensive tactics: gaining access, moving laterally, and demonstrating impact without causing damage
- **blue team**
  - defends the organization by detecting, analyzing, and responding to attacks in real time
  - focuses on monitoring, incident response, and strengthening systems to prevent future intrusions
- **purple team**
  - acts as a bridge between Red and Blue teams to share insights and improve both offense and defense.

2 Terminology - White, Grey, and Black Hat Hackers

- hackers are often described using *hat* colors to indicate their intentions and legality.

- **white hat**
  - ethical hackers who test systems with permission to strengthen security
  - follow laws, responsible disclosure, and professional standards (e.g., penetration testers, security researchers)
- **grey hat**
  - operate in the grey area; may test or expose vulnerabilities without authorization but usually without malicious intent
  - often aim to raise awareness, but still risk breaking the law due to unauthorized access
- **black hat**
  - malicious hackers who exploit systems without consent for personal gain, theft, or sabotage
  - intentionally cause harm, steal data, or sell exploits — their actions are clearly illegal and unethical

2 Terminology - White Box, Grey Box, and Black Box Testing

- the terms white box, grey box, and black box describe how much information the tester has about the target before starting

- **white box**
  - the tester has full knowledge of the system (including source code, architecture, credentials, and internal documentation) allowing for a deep and efficient security review
- **grey box**
  - the tester has limited or partial knowledge (for example, user-level access or some internal details), simulating an attacker with insider or partial information
- **black box**
  - the tester has no prior information about the target, approaching it like an external attacker and discovering everything from scratch through reconnaissance

Introduction to Ethical Hacking

1	Motivation
2	Terminology
3	Methodologies & Frameworks
4	Legal & Ethical Boundaries
5	Important Bodies & Organizations
6	Certifications

3 M&F - Methodologies

- **methodology**
  - structured process or workflow used to conduct a penetration test
  - defines how each phase is performed
  - purpose
    - prevent inconsistency and ad-hoc work in security testing
    - turn informal probing into a repeatable, auditable process
    - define what to do, when to do it, and how to document results

  ⇒ think of a map or step-by-step route you follow to get somewhere
- examples:
  - PTES (Penetration Testing Execution Standard)
  - OSSTMM (Open Source Security Testing Methodology Manual)
  - NIST SP 800-115

3 M&F - Framework

- **framework**
  - is a reference model or taxonomy
  - provides what to test for and how to classify or describe the results
  - purpose
    - provide a shared language and classification systems for findings
    - help teams map attacker behavior to defensive controls and detection

⇒ think of a catalog or classification system that helps you describe and organize what you find along the journey

- examples:
  - OWASP (Open Web Application Security Project)
  - MITRE ATT&CK
  - NIST Cybersecurity Framework (CSF)

3 M&F - Common Penetration Methodology

1. **reconnaissance / information gathering:**
   - passive collection of public info (DNS, WHOIS, job posts, search engines) to map the target
   - active probes (port scans, banner grabs, directory/user enumeration) to list services and versions
2. **exploitation**: use gathered intelligence to take advantage of a vulnerability and gain a controlled foothold on target system
3. **privilege escalation**: techniques to gain higher privileges on a compromised host
4. **post-exploitation & pivoting**: maintain/establish long-term access and move laterally to reach other assets
5. **reporting & remediation**: triage findings, deliver executive summary and technical fixes and a retest plan

Introduction to Ethical Hacking

1	Motivation
2	Terminology
3	Methodologies & Frameworks
4	Legal & Ethical Boundaries
5	Important Bodies & Organizations
6	Certifications

4 Legislature in Germany - § 202A

§ 202a - Ausspähen von Daten

(1) Wer unbefugt sich oder einem anderen Zugang zu Daten, die nicht für ihn bestimmt und die gegen unberechtigten Zugang besonders gesichert sind, unter Überwindung der Zugangssicherung verschafft, wird mit Freiheitsstrafe bis zu drei Jahren oder mit Geldstrafe bestraft.

(2) Daten im Sinne des Absatzes 1 sind nur solche, die elektronisch, magnetisch oder sonst nicht unmittelbar wahrnehmbar gespeichert sind oder übermittelt werden.

§ 202c - Vorbereiten des Ausspähens und Abfangen von Daten

(1) Wer eine Straftat nach § 202a oder § 202b vorbereitet, indem er

(a) Passwörter oder sonstige Sicherungscodes, die den Zugang zu Daten (§ 202a Abs. 2) ermöglichen, oder

(b) Computerprogramme, deren Zweck die Begehung einer solchen Tat ist, herstellt, sich oder einem anderen verschafft, verkauft, einem anderen überlässt, verbreitet oder sonst zugänglich macht, wird mit Freiheitsstrafe bis zu zwei Jahren oder mit Geldstrafe bestraft.

(2) § 149 Abs. 2 und 3 gilt entsprechend.

§ 303a - Datenveränderung

(1) Wer rechtswidrig Daten (§ 202a Abs. 2) löscht, unterdrückt, unbrauchbar macht oder verändert, wird mit Freiheitsstrafe bis zu zwei Jahren oder mit Geldstrafe bestraft.

(2) Der Versuch ist strafbar.

(3) Für die Vorbereitung einer Straftat nach Absatz 1 gilt § 202c entsprechend.

§ 303b - Computersabotage

(1) Wer eine Datenverarbeitung, die für einen anderen von wesentlicher Bedeutung ist, dadurch erheblich stört, dass er

(a) eine Tat nach § 303a Abs. 1 begeht

(b) Daten (§ 202a Abs. 2) in der Absicht, einem anderen Nachteil zuzufügen, eingibt oder übermittelt oder

(c) eine Datenverarbeitungsanlage oder einen Datenträger zerstört, beschädigt, unbrauchbar macht, beseitigt oder verändert,

wird mit Freiheitsstrafe bis zu drei Jahren oder mit Geldstrafe bestraft.

(2) Handelt es sich um eine Datenverarbeitung, die für einen fremden Betrieb, ein fremdes Unternehmen oder eine Behörde von wesentlicher Bedeutung ist, ist die Strafe Freiheitsstrafe bis zu fünf Jahren oder Geldstrafe.

(3) Der Versuch ist strafbar.

(4) In besonders schweren Fällen des Absatzes 2 ist die Strafe Freiheitsstrafe von sechs Monaten bis zu zehn Jahren. Ein besonders schwerer Fall liegt in der Regel vor, wenn der Täter [...]

(5) Für die Vorbereitung einer Straftat nach Absatz 1 gilt § 202c entsprechend.

§ 263a - Computer Betrug

(1) Wer in der Absicht, sich oder einem Dritten einen rechtswidrigen Vermögensvorteil zu verschaffen, das Vermögen eines anderen dadurch beschädigt, daß er das Ergebnis eines Datenverarbeitungsvorgangs durch unrichtige Gestaltung des Programms, durch Verwendung unrichtiger oder unvollständiger Daten, durch unbefugte Verwendung von Daten oder sonst durch unbefugte Einwirkung auf den Ablauf beeinflußt, wird mit Freiheitsstrafe bis zu fünf Jahren oder mit Geldstrafe bestraft.

(2) § 263 Abs. 2 bis 6 gilt entsprechend.

(3) Wer eine Straftat nach Absatz 1 vorbereitet, indem er

- *(a) Computerprogramme, deren Zweck die Begehung einer solchen Tat ist, herstellt, sich oder einem anderen verschafft, feilhält, verwahrt oder einem anderen überlässt oder*
- *(b) Passwörter oder sonstige Sicherungscodes, die zur Begehung einer solchen Tat geeignet sind, herstellt, sich oder einem anderen verschafft, feilhält, verwahrt oder einem anderen überlässt, wird mit Freiheitsstrafe bis zu drei Jahren oder mit Geldstrafe bestraft.*

(4) In den Fällen des Absatzes 3 gilt § 149 Abs. 2 und 3 entsprechend.

4 Permission-based Testing

- Before any active testing on systems you do not own you must have explicit, written authorization from the owner. At a minimum that authorization should include:
  - Written authorization & signatories
  - Clear scope
  - Allowed techniques & denied techniques
  - Time window & contact points
  - Rules for data
  - Reporting, remediation & liability

Introduction to Ethical Hacking

1	Motivation
2	Terminology
3	Methodologies & Frameworks
4	Legal & Ethical Boundaries
5	Important Bodies & Organizations
6	Certifications

5 Important Bodies & Organizations - ISO

- International Organization for Standardization
- develops and publishes international standards for nearly every industry, including information security (e.g. ISO 27001)
- produces certifiable international standards used by governments and industry to set requirements and enable international interoperability and trade.



5 Important Bodies & Organizations - NIST

- National Institute of Standards and Technology
- a U.S. federal agency that publishes detailed standards, special publications, frameworks, and guidance (e.g., NIST SP 800-series, NIST CSF)
- produces practical cybersecurity guidance, measurement science, and best-practice frameworks used by U.S. agencies and many private-sector organizations worldwide

NIST
National Institute of
Standards and Technology

5 Important Bodies & Organizations - OWASP

- Open Web Application Security Project
- a non-profit community that produces freely available resources focused on application security (notably the OWASP Top Ten)
- concerns itself with awareness, developer guidance, toolkits, and open projects aimed at improving secure coding and web/app security practices



5 Important Bodies & Organizations - FIRST

- Forum of Incident Response and Security Teams
- a global association of incident response teams and product-security teams
- coordination and best practices for incident response, vulnerability handling, trusted information sharing, and standards for CSIRT services
- official custodian and maintainer of the CVSS standard



5 Important Bodies & Organizations - BSI

- Bundesamt für Sicherheit in der Informationstechnik
- Germany’s federal office for information security
- develops national IT-security standards, certifies products, and responds to cyber threats

Bundesamt
für Sicherheit in der
Informationstechnik

Introduction to Ethical Hacking

1	Motivation
2	Terminology
3	Methodologies & Frameworks
4	Legal & Ethical Boundaries
5	Important Bodies & Organizations
6	Certifications

6 Certifications

- certifications for ethical hacking are plenty
- different levels of complexity











